DATA SUBJECT DELETION RIGHTS IN GDPR PIPEDA & CCPA

Group Members:
Max Forrest
Karanveer Singh
Chirag Kumar
Sukhmanveer Singh

Data Subject Deletion Rights Comparing Frameworks

Question 1: Similarities and Differences in Deletion Rights Across Frameworks

Right to Deletion

AI

GDPR – Right to be Forgotten

Known as the "right to be forgotten," individuals can request the deletion of personal data when it is no longer necessary or when they withdraw consent.

AI

CCPA – Right to Deletion

Consumers can request the deletion of their personal information collected by businesses, with certain exemptions.

AI

PIPEDA

Individuals have the right to request the deletion of their personal information when it is no longer needed for the purposes for which it was collected.

Sources: GDPR Article 17, CCPA §1798.105, PIPEDA 4.5, Palmieri (2020)

Key Differences

ASPECT	GDPR	CCPA	PIPEDA
Scope of Applicability	Data controllers and processors handling data of those physically in the EU.	Large, for-profit businesses handling data of California residents and doing business in the state.	Private sector for-profit and federally regulated organizations that operate in Canada.
Conditions for Rectification	Requests must be followed within 1-3 months.	Verified requests must be followed in 45-90 days.	Requests must be followed within 30-60 days.
Conditions for Deletion	Data subjects' valid deletion requests must be fulfilled unless retention required under one of five exceptions.	Consumers' verified deletion requests must be fulfilled unless covered by one of eight exemptions.	No right to deletion until data no longer required for purpose for which it was collected.
Enforcement Mechanism	Enforcement by member-state Data Protection Authorities; penalties include fines and sanctions	Enforcement through California Attorney General; civil penalties and fines	Overseen by the Office of the Privacy Commissioner of Canada; enforcement via federal courts and audits.

Sources: GDPR Article 16, 17, 58, 83; CCPA §1798.105, Office of the Attorney General, PIPEDA 4.5

Consumer Deletion Rights

GDPR

- Data subjects may request data deletion under six grounds.
- Five exemptions exist

CCPA

- Consumers may request the deletion of their data for any reason.
- Nine exemptions exist

PIPEDA

- Data deletion only required after data no longer necessary.
- No general right to deletion

Sources: GDPR Article 17, CCPA §1798.105, PIPEDA 4.5

Ease of Access

AI

GDPR

GDPR provides a clearer, more formal structure for individuals to follow when exercising their rights.

AI

CCPA

CCPA's framework is less formalized

AI

PIPEDA

PIPEDA requires organizations to provide methods for individuals to access and correct their information.

Sources: GDPR Article 12, CCPA §1798.105, PIPEDA 4.9

System Architectures for Data Subject Deletion Rights

Question 2: Architectures, Features & Implementation Approaches

Architecture Approaches: Centralized vs Decentralized

Centralized Architecture

Single repository stores all personal data

- Simpler deletion execution
- Unified user interface
- Centralized audit logs
- Easier compliance reporting

Key Features:

- Comprehensive data catalog
- Role-based access controls
- Single deletion workflow

Challenge: Scaling limitations

Decentralized Architecture

Data distributed across multiple systems

- Scales with organization
- Mirrors actual infrastructure
- Team autonomy maintained
- Resilient to single point failure

Key Features:

- Data mapping across systems
- Interoperable APIs
- Synchronization mechanisms

Challenge: Coordination complexity

Sources: Twitter Engineering (2020) - Distributed Deletion Architecture, Meta DELF Framework (2020), Information Commissioner's Office (2025)

Hybrid Approach & The Blockchain Problem

Hybrid Architecture: Best of Both Worlds

Combines centralized control with decentralized data storage. **Features include:**
• Unified API gateway for deletion requests • Backend systems remain distributed • Orchestration layer coordinates deletion across services

Reality: Most large organizations use hybrid architectures

⚠ The Blockchain Problem: Immutability vs. Deletion

Blockchain is fundamentally **immutable** - data cannot be deleted once written. This **directly conflicts** with the right to deletion.

Proposed workarounds:

- Chameleon hashing (allows rewriting blocks, defeats immutability purpose)
- Store only encrypted data + delete keys (cryptographic erasure, but then why use blockchain?)
- Store pointers to off-chain data (actual data not on blockchain, defeats transparency goal)

Verdict: Blockchain is NOT recommended for implementing deletion rights

Sources: Finck & Moscon (2019) - Blockchain & GDPR, Politou et al. (2019) - Blockchain vs Privacy

Essential Features for Deletion Systems

1 User Request Interface

Intuitive dashboard for users to submit deletion requests easily

2 Identity Verification

Multi-factor authentication to prevent unauthorized deletion requests

3 Data Inventory/Catalog

Comprehensive map of where personal data resides across all systems

4 Compliant Workflows

Defined processes aligning with GDPR (1 month), CCPA (45 days) timelines

5 Audit & Compliance Logs

Immutable records of all deletion requests and actions for accountability

6 Notification System

Automated alerts to inform users of deletion request status and completion

7 Data Retention Policies

Rules for when data can be retained despite deletion requests (legal holds)

8 Secure Destruction

Cryptographic erasure or physical destruction methods (NIST SP 800-88)

Sources: GDPR Article 12, CCPA §1798.105, NIST SP 800-88, IAB Data Deletion Framework (2024)

Challenges in Implementing Data Subject Deletion Rights

Question 3: Implementation Challenges, Accidental Deletion & Backup Management

Key Implementation Challenges

1. **Data Mapping & Identification**

   Identifying all instances of personal data across decentralized databases and legacy systems

2. **Verification Processes**

   Balancing security (preventing fraudulent requests) with usability (avoiding friction for legitimate users)

3. **System Complexity**

   Integrating deletion capabilities into existing systems, especially legacy environments without modern APIs

4. **Legal Compliance**

   Navigating multiple regulations (GDPR, CCPA, PIPEDA) with different requirements and timelines

5. **Retention Policy Conflicts**

   Balancing deletion requests with legal obligations to retain data (e.g., financial records, litigation holds)

6. **Employee Training**

   Ensuring staff understand policies and procedures to avoid accidental or incorrect deletions

Sources: GDPR Article 17, CCPA §1798.105, NIST SP 800-88

Accidental Deletion & Backup Management

Risks of Accidental Deletion

- Wrong data subject's data deleted
  → *Privacy breach, regulatory penalties*
- Data needed for legal compliance deleted
  → *Violation of retention requirements*

Mitigation Strategies

- Multi-step verification *(email confirmation, 2FA)*
- Audit trails *(log all actions)*
- Soft deletion *(temporary retention)*

The Backup Deletion Challenge

GDPR Recital 65: Data in backups 'should not be available for other processing purposes.' Immediate deletion from backups is **not explicitly required**. Organizations typically implement a **'restore and delete' approach**: *backups are kept for disaster recovery, but deleted data must be removed **before** any backup is restored for use.*

Sources: GDPR Recital 65, NIST SP 800-88 (Kissel et al., 2014), Reardon et al. (2013)

Architectural Solutions to Address Challenges

Data Mapping Tools

Centralized data inventory systems identify all instances of personal data across platforms (e.g., Collibra, OneTrust)

Integrated Verification Systems

OAuth, SAML, knowledge-based authentication, and document verification streamline identity checks

Modular Systems for Compliance

Microservices architectures allow updating compliance logic for specific regulations without system overhauls

Cryptographic Erasure

Destroying encryption keys makes data irrecoverable-scalable solution for distributed systems and backups

Key Insight: Effective deletion requires coordinated technical, organizational, and legal measures across the entire data lifecycle

Sources: Twitter Engineering (2020), Meta DELF Framework (2020), IAB Data Deletion Framework (2024)

Secure Deletion Frameworks

Question 4: Cryptographic Mechanisms & Regulatory Requirements

What is Secure Deletion?

Technical and organizational mechanisms that ensure personal data becomes

IRRECOVERABLE and UNUSABLE

Physical Overwriting

Writing random data multiple times over storage blocks. Ineffective for SSDs, cloud storage, and distributed systems due to wear-leveling and abstraction.

Logical Deletion

Removing database references or marking records inactive. Data may still exist in backups, logs, caches, and analytics datasets. Not sufficient for regulatory compliance.

Cryptographic Erasure

Modern best practice. Encrypting data at rest with unique keys, then permanently destroying keys. Makes data irrecoverable even if copies exist in backups or caches.

Unlike simple logical deletion, secure deletion guarantees data cannot be restored through forensic recovery, backups, or residual storage artifacts

Sources: Reardon et al. (2013) - SoK: Secure Data Deletion (IEEE S&P), NIST SP 800-88 (Kissel et al., 2014)

How Cryptographic Erasure Works

1. **Encrypt Data at Rest**
   All personal data is encrypted using strong symmetric encryption (e.g., AES-256) before storage

2. **Unique Encryption Keys**
   Each dataset or user's data is encrypted with a unique Data Encryption Key (DEK)

3. **Secure Key Storage**
   Encryption keys are stored separately in a Key Management System (KMS) or Hardware Security Module (HSM)

4. **Key Destruction on Deletion**
   When deletion is required, the encryption key is permanently destroyed, making the ciphertext irrecoverable

Result: Even if encrypted data exists in backups, logs, or caches, it's permanently unusable without the key

Sources: Garg et al. (2020) - Formalizing Data Deletion (EUROCRYPT), Shoup (2020) - Cryptographic Key Management for Data Deletion

Cryptographic Mechanisms Involved

Symmetric Encryption

Algorithm: AES-256 (Advanced Encryption Standard)
How it works: Same key encrypts and decrypts data. Destroying this key makes ciphertext unusable.

Hierarchical Keys

Structure:
- Root/Master Key
- Data Encryption Keys (DEK)
- User/dataset-specific keys

Benefit: Destroying a specific DEK allows targeted deletion without affecting other data

Hashing for Indexing

Algorithm: SHA-256 (Secure Hash Algorithm)
Use case: Index user identifiers (e.g., hashed emails) to locate data across systems
Note: Hashing alone ≠ deletion

Key Lifecycle Controls & Security

Key Rotation: Regular key updates to limit exposure window
Hardware Security Modules (HSMs): Tamper-resistant devices for secure key storage
Audit Logs: Immutable records of all key creation, use, and destruction events
Access Controls: Strict authorization policies limiting who can destroy keys

Sources: NIST SP 800-88, Shoup (2020) - ISO Proposal for Key Management, Garg et al. (2020)

Do Regulations Require Secure Deletion?

No regulations explicitly mandate cryptographic erasure, but they impose outcome-based requirements

GDPR

Article 17: Right to erasure
Article 32:
"Appropriate technical and organizational measures"

Implication:
If data remains recoverable after deletion request, regulators may determine erasure was **ineffective**. Secure deletion may be **necessary to demonstrate compliance**

CCPA

Section 1798.105: Right to deletion

Requirement: Businesses must delete data from their systems **and** instruct service providers to do the same

Implication:
Deletion must be **meaningful and not merely symbolic**. While not specifying technical methods, the intent is **irrecoverability**

PIPEDA

Principle 4.5: Retention & disposal

Requirement:
Organizations must retain data only as long as necessary, then *"destroy, erase, or anonymize"*

Implication:
While not prescribing cryptographic methods, secure destruction implies **irreversibility**. Effective deletion = data cannot be restored

In modern cloud & distributed environments, cryptographic erasure is the most scalable and legally defensible method

Sources: GDPR Articles 17 & 32, CCPA §1798.105, PIPEDA Principle 4.5, OPC Guidance (2025)

Overview of the IAB's Data Deletion Framework

Question 5: How does the IAB's Data deletion framework operate? What stakeholders are involved? Show an example of a data flow in this framework.

IAB Data Deletion Request Framework

The Data Deletion Request Framework provides a standard approach for handling data deletion requests within the adtech ecosystem. This framework establishes a standardized mechanism for transmitting data deletion requests signals throughout the digital advertising chain.

Sources: IAB Data Deletion Request Framework (2024) – GitHub

Stakeholders & Roles

1

Publishers (First Parties)

- Own the user relationship (e.g., news sites, apps).
- Initiate deletion requests to their partners.

2

Vendors (DSPs, SSPs, exchanges, agencies, DMPs, etc.)

- Receive user data from publishers.
- Receive and process deletion requests from publishers.

3

Consumers (Data Subjects)

- Individuals whose data is subject to deletion requests under privacy regulations.

Sources: IAB Data Deletion Request Framework 2024, IAB Tech Lab Deep Dive 2023

Framework Specifications

1. **Identity JWT (idJWT)**

   Contains consumer identifier (hashed via SHA-256). Signed by publisher.

2. **Request JWT (rqJWT)**

   Wraps idJWT + request metadata (request ID, timestamp). Signed by publisher. Sent to vendor endpoint.

3. **Acknowledgement JWT (acJWT)**

   Returned by vendor with status (received | processed | failed), transaction_id, message. Signed by vendor.

Before sending deletion requests, publishers must discover vendor endpoints and obtain cryptographic keys. DDRFsolves this through dsrdelete.json - a standardized configuration file every vendor publishes containing their deletionendpoint, supported identifier formats, and Ed25519 public keys (JWKS).

Sources: IAB Data Deletion Request Framework 2024, IAB Tech Lab Deep Dive 2023

Discovery & Verification: JWKS & dsrdelete.json

1

JWKS (JSON Web Key Sets)

Public keys used to verify JWT signatures. Each organization publishes its dsrdelete.json file containing JWKS with Ed25519 public keys.

2

dsrdelete.json

Standardized configuration file published by every vendor at: https://vendor-domain.com/dsrdelete.json

Contains:

- Deletion request endpoint URI
- Supported identifier formats (email, IDFA, GAID)
- Identifier hashing algorithm (SHA-256)
- Public keys (JWKS) for signature verification

Sources: IAB Data Deletion Request Framework 2024, IAB Tech Lab Deep Dive 2023

DATA FLOW IN IAB DDRF

1. **Consumer Initiates Request**

   Consumer submits deletion request to publisher's website

2. **Publisher Discovers Vendor Endpoints**

   Publisher fetches vendor's dsrdelete.json file to retrieve endpoint URI, supported identifier formats, and public keys.

3. **Publisher Encodes Request**

   Publisher creates Identity JWT (idJWT) containing hashed consumer identifier.
   Publisher wraps idJWT inside Request JWT (rqJWT) with request metadata (ID, timestamp).
   Publisher signs rqJWT with its private key.

4. **Publisher Sends Request**

   Publisher sends signed rqJWT via HTTPS POST to vendor's deletion endpoint (discovered from dsrdelete.json).

Sources: IAB Data Deletion Request Framework 2024, IAB Tech Lab Deep Dive 2023

DATA FLOW IN IAB DDRF (contd..)

5 Vendor Verifies Request

Vendor retrieves publisher's public key from publisher's dsrdelete.json.
Vendor uses public key to verify rqJWT signature.
If signature is valid, vendor confirms request came from legitimate publisher.

6 Vendor Processes Deletion

Vendor processes deletion request against its database and internal systems.

7 Vendor Sends Acknowledgement

Vendor creates Acknowledgement JWT (acJWT) containing:

- status: received | processed | failed
- transaction_id: Unique identifier linking to request
- message: Human-readable status or error details

Vendor signs acJWT with its private key.
Vendor sends acJWT back to publisher via HTTPS.

8 Publisher Notifies Consumer

Publisher receives acJWT and informs consumer of deletion outcome (regulatory requirement under GDPR/CCPA, not part of DDRF spec).

Sources: IAB Data Deletion Request Framework 2024, IAB Tech Lab Deep Dive 2023

Thank You!

References

[1] Exercise your rights! | noyb.eu. Retrieved February 19, 2026 from https://noyb.eu/en/exercise-your-rights
[2] Interactive Advertising Bureau. 2025. Data Subject Rights. Retrieved February 19, 2026 from https://github.com/InteractiveAdvertisingBureau/Data-Subject-Rights
[3] Richard Kissel, Andrew Regenscheid, Matthew Scholl, and Kevin Stine. 2014. Guidelines for Media Sanitization. National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-88r1
[4] Joel Reardon, David Basin, and Srdjan Capkun. 2013. SoK: Secure Data Deletion. In 2013 IEEE Symposium on Security and Privacy, May 2013. IEEE, Berkeley, CA, 301–315. https://doi.org/10.1109/SP.2013.28
[5] European Union. (2016). Regulation (EU) 2016/679 (General Data Protection Regulation), Article 17 - Right to erasure ('right to be forgotten'). *Official Journal of the European Union*, L 119/1. https://gdpr-info.eu/art-17-gdpr/
[6] California Legislature. (2018). California Consumer Privacy Act, Civil Code Section 1798.105 - Consumers' Right to Deletion. As amended by California Privacy Rights Act (2020). https://leginfo.legislature.ca.gov/faces/codes_displaySection.xhtml?lawCode=CIV&sectionNum=1798.105
[7] Government of Canada. (2000). Personal Information Protection and Electronic Documents Act (PIPEDA), Schedule 1, Principle 4.5 - Limiting Use, Disclosure, and Retention. S.C. 2000, c. 5. https://www.priv.gc.ca/en/privacy-topics/privacy-laws-in-canada/the-personal-information-protection-and-electronic-documents-act-pipeda/p_principle/principles/p_use/
[8] Sanjam Garg, Shafi Goldwasser, and Prashant Nalini Vasudevan. 2020. Formalizing Data Deletion in the Context of the Right to Be Forgotten. *In Advances in Cryptology – EUROCRYPT 2020*, Anne Canteaut and Yuval Ishai (eds.). Springer International Publishing, Cham, 373–402. https://doi.org/10.1007/978-3-030-45724-2_13

References

[9] Manos Athanassoulis, Subhadeep Sarkar, Tarikul Islam Papon, Zichen Zhu, and Dimitris Staratzis. 2022. Building Deletion-Compliant Data Systems. *A Quarterly bulletin of the Computer Society of the IEEE Technical Committee on Data Engineering* 45, 1 (2022). Retrieved from https://par.nsf.gov/servlets/purl/10342159

[10] Jared Moscow, Brian May, and Kale Smith. 2023. Taking Charge Of Your Data: A Deep Dive into the Data Deletion Request Framework. Retrieved from https://iabtechlab.com/wp-content/uploads/2023/11/Deep-Dive-on-Data-Deletion-Request-Framework.pdf

[11] 2024. Data Deletion Request Framework. *IAB Tech Lab*. Retrieved February 20, 2026 from https://iabtechlab.com/standards/data-deletion-request-framework/

[12] Kacey Perinelli. 2024. What Is Iab Tech Lab's Data Deletion Request Framework & How Will It Simplify Data Deletion? *AdMonsters*. Retrieved February 20, 2026 from https://www.admonsters.com/what-is-iab-tech-labs-data-deletion-request-framework/

[13] Victor Shoup. 2020. A Proposal for an International Standard on Cryptographic Key Management for Data Deletion. NIST Cryptographic Technology Research Group. Retrieved from https://shoup.net/papers/iso-2_1.pdf

[14] Office of the Privacy Commissioner of Canada. 2025. Personal Information Retention and Disposal: Principles and Best Practices. *Office of the Privacy Commissioner of Canada*. Retrieved from https://www.priv.gc.ca/en/privacy-topics/business-privacy/breaches-and-safeguards/safeguarding-personal-information/gd_rd_201406/

[15] 2018. California Consumer Privacy Act (CCPA). *State of California - Department of Justice - Office of the Attorney General*. Retrieved February 20, 2026 from https://oag.ca.gov/privacy/ccpa

[16] Nicholas F. III Palmieri. 2020. Who Should Regulate Data: An Analysis of the California Consumer Privacy Act and Its Effects on Nationwide Data Protection Laws. *Hastings Science and Technology Law Journal* 11, (2020).

[17] 2025. Right to erasure. *Information Commissioner's Office*. Retrieved February 27, 2026 from https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/individual-rights/individual-rights/right-to-erasure/